Thử nghiệm vòng phản hồi trên PR thật — 02/11/2026

Mục tiêu: chứng minh ba lớp tự học chạy thật trên GitHub, không chỉ trong unit test: lớp 1 (người trả lời / bấm 👍 👎 → `repo_memory`), lớp 2 (agent tự rút ghi chú sau mỗi lần review), lớp 5 (hiệu chỉnh confidence theo tỉ lệ 👎, `app/review/calibrate.py`).

Môi trường: GitHub App `hermesqabot` cài trên `zuberg0811/HermesQA`, subscribe hai event *Pull request* và *Pull request review comment*; webhook đi qua tunnel Cloudflare về `docker compose` trên máy dev (api, worker, redis, postgres). Model review: Gemini (`LLM_MODEL` mặc định), static tools trong sandbox Docker. PR thử: #1, nhánh `c8/feedback-test`, ba file `examples/c8_demo*.py` có lỗi cố ý (secret hard-code, `shell=True`, `verify=False`, `open()` không `encoding`, bare `except`, chia cho 0).

Bốn vòng

Vòng	Commit	Thao tác người	Bot làm gì	Bằng chứng
1	`723d280`	mở PR	đăng 5 comment inline (3 security, 2 bug) từ static tools; agent tự ghi 1 ghi chú	log `posted=5`, `reflect: learned 1 note`
2	`a0720cb`	reply "không phải lỗi..." vào comment `unspecified-open-encoding`; 👎 `E722`; 👎 `disabled-cert-validation`; 👍 secret	webhook `pull_request_review_comment` → ghi reject ngay; lần push đọc 3 reaction	bảng `feedback` 4 dòng (1 reply, 3 reaction)
3	`0420221`	thêm file mới lặp lại hai mẫu	đăng lại 2 comment trên file mới (mới có 1 👎 mỗi mẫu, chưa đủ ngưỡng 2)	`posted=2`
4	`adfbb8b`	👎 cả hai comment ở file mới; thêm file thứ ba lặp lại hai mẫu	đọc 2 👎 mới → mỗi mẫu đủ 2 reject → confidence 95% → 47% < ngưỡng 60% → **không đăng** hai mẫu đó nữa; vẫn đăng lỗi chia cho 0 do LLM tìm thấy	log `calibrated 8 finding(s)`, `posted=1`

Trích log vòng 4:

```
feedback ... reject via reaction: KHÔNG báo lại: examples/c8_demo2.py — [bug] unspecified-open-encoding (luật s
feedback ... reject via reaction: KHÔNG báo lại: examples/c8_demo2.py — [bug] E722 (luật ruff)
calibrated 8 finding(s) from feedback: examples/c8_demo.py:26 95%->47% (semgrep:unspecified-open-encoding | exa
done PR #1 conclusion=neutral posted=1 repeated=3
```

Nhận xét

- **Cả hai kênh phản hồi hoạt động.** Reply được ghi trong vòng 2 giây sau khi gửi. Reaction không có webhook, được đọc ở lần push kế tiếp như thiết kế; người dùng cần biết điều này (ghi trong README).
- **Lớp 5 chạy đúng ngưỡng.** Một 👎 chưa đổi gì (vòng 3), hai 👎 cùng cặp luật + thư mục hạ confidence xuống dưới ngưỡng đăng (vòng 4). Ghi chú 👎 về lỗi bảo mật (`disabled-cert-validation`) được đánh dấu "chỉ tham khảo, vẫn báo" và không bị hạ, đúng hàng rào.
- **Lớp chống đăng lại che lớp học.** Dấu vân tay = file + luật + nội dung dòng code. Lặp lại mẫu trong cùng file bị coi là comment cũ (`repeated`), nên muốn thấy tác dụng của phản hồi phải tạo file khác. Đây là lý do

thử nghiệm cần 4 vòng thay vì 2.

- **Lớp 2 học cả từ mô tả PR.** Ghi chú agent tự rút ở vòng 1: "Thư mục examples/ chứa các file demo cố tình vi phạm bảo mật để test bot, không cần báo lỗi nghiêm trọng tại đây", lấy ý từ phần mô tả PR. Học đúng ý tác giả, nhưng cũng cho thấy mô tả PR có thể dạy bot bỏ qua lỗi; đây là điểm cần nêu ở phần hạn chế (prompt injection qua PR body).
- **Lỗi tìm thấy nhờ thử thật:** id comment GitHub đã vượt 2^31 (`4444869769`), cột `comment_id` INTEGER của Postgres bị tràn làm `link_comment_ids` thất bại ở vòng 1; đã sửa sang BIGINT kèm migrate (commit `42606ef`). Nếu không thử trên GitHub thật, lỗi này không lộ vì test dùng SQLite (INTEGER 64-bit).
- **Gemini 503/timeout** trong 3 trên 4 vòng làm vai SE/QA không chạy, chỉ còn static tools. Không ảnh hưởng kết luận về lớp 1 và 5 (đều không cần LLM) nhưng cho thấy cần cơ chế gọi lại khi API quá tải (đã thêm cho giám khảo eval, chưa thêm cho pipeline review).

Lệnh kiểm tra DB dùng trong thử nghiệm:

```
docker compose exec postgres psql -U hermesqa -c "select channel, kind, comment_id from feedback;"
docker compose exec postgres psql -U hermesqa -c "select source, kind, file, note from repo_memory;"
```